Interaktivní osvěta kybernetické bezpečnosti

Marek Roháč
Matyáš Vilím
Kryštof Troják

Rozložení úkolů

1. analýza falešných emailů
    1. Vzdálený příbuzný
    2. Viry v makru
    3. Záměna znaků
2. identifikace falešné stránky
3. vytváření silného heslo
4. analýza spear phisingu a OSINT

Rozložení CTF

- Windows - plnění úkolů
- WSL – slouží jako backend server

windows

- Pro splnění CTF je potřeba
  - Prohlížeč
  - Libreoffice calc
  - Ping v cmd
- Pro směrování domén CTF používá hosts
- Self signed certifikát ze serveru je nainstalovaný jako důvěryhodný (pro úkol 5)

server

- Všechno je dockerizované do 2 imagu (mailhog a ctf)
- Server používá:
  - nginx pro statické stránky
  - PHP pro dynamické stránky
  - Python pro http server a whois web
  - Mailhog pro emaily
- Swaks – odesílání emailů
- Ve VM běží na WSL
- Pro úkol s certifikátem se vygeneruje self-signed certifikát
- Emaily se odešlou při nastartování VM

Analýza emailů

1) Vzdálený příbuzný neboli nigerský princ
   - Analyzovat gramatické chyby a zjistit lokaci IP adresy odkazu pomocí pingu a ip lokátoru
2) Stažení excel dokumentu
   - Zjistit jaké viry by byli staženy při spuštění maker
   - Bonusový úkol – do jaké složky by se viry stáhly
3) Podvržené domény
   - Najít znaky v doménách z emailu, kde jedna obsahuje typosquatting a druhá obsahuje homoglyphy

mailhog

MailHog

Search

GitHub

Connected

Inbox (3)

Delete all messages

50 1-3 of 3

Radim Romanovský "victim@email.cz"	**Vyplnění dotazníku**	5 minutes ago 20.92 kB
Microsoft Security Team "victim@email.cz"	**Podezřelé přihlášení k vašemu účtu**	5 minutes ago 394 B
Jarmila "victim@email.cz"	**Odevzdání dědictví**	5 minutes ago 743 B

Jim

Jim is a chaos monkey.
Find out more at GitHub.

Enable Jim

Analýza falešné stránky

- Cílem je dostat se na stránku obcanportalgov.cz přes stránku novinky-aktualne.autos
- Z obcanportalgov.cz musí uživatel analyzovat:
  - vydavatele certifikátu
  - zjistit whois záznamy (jméno, příjmení a zemi registranta a zemi registrátora)
- Ještě zjistit certifikát reálné stránky obcan.portal.gov.cz

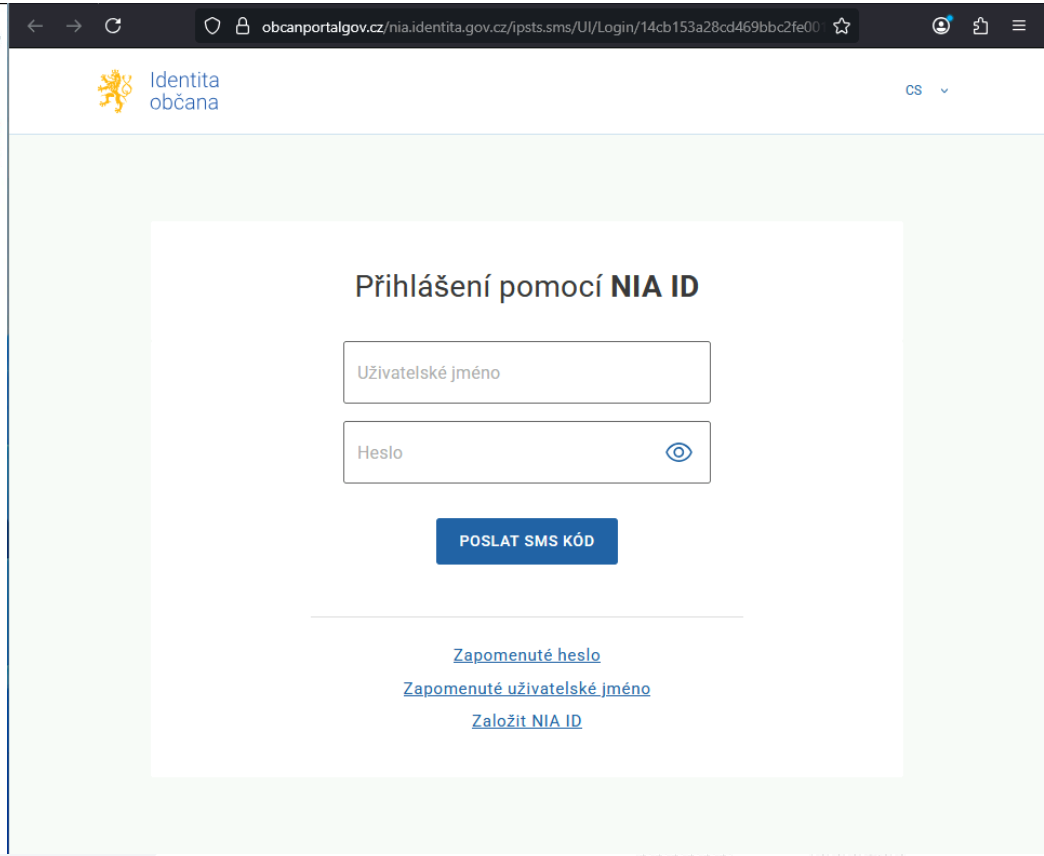
Podvodné stránky

Andrej Babiš: Chápu, o čem mluvíte. Chápu, o čem mluvíte. Dokonce jsem rád, že jsme se dotkli tohoto tématu, protože lidé by měli znát pravdu...

Spojení mezi těmito událostmi určitě existuje. Přibližně před několika měsíci mě zaujal národní **projekt s názvem KerenTechAI od České národní banky.** Podstata je v tom, že každý občan země se může stát účastníkem a počítat s velkou sociální pomocí. Problém spočívá v tom, že projekt nedostal dostatečnou reklamu, takže o MerenTechAI ví jen málokdo.

Spolu se stranou ANO jsme provedli analýzu a zjistili, že **na MerenTechAI lze vydělat od 40 000 korun měsíčně.** Česká národní banka tento proje[illegible]a, protože může zcela změnit ekonomiku země a blahobyt lidí.

STÁT SE ČLENEM



Vytvoření silného hesla

- Cílem je
  - změnit si heslo aby jeho entropie dosahovala přijatelné výše
  - dále si ho zapamatovat
  - po vypočtení jednoduchých příkladů se sním znovu přihlásit
- Úkol obsahuje video, kde je ukázáno, jak lze prolomit heslo, které se skládá ze zálib a dalších údajů o osobě.
- Při dokončení úlohy se uživateli odešle spear phisingový email

Spear phising

- Cílem je přečíst si spear phisingový email a na 2 sociálních sítích označit příspěvky, které pomohli útočníkům ve vytváření emailu
- Sociální sítě:
  - Klon instagramu - slowrgram
  - Klon linkedinu - syncdln
- Aplikace má toleranci na 2 špatně zadané nebo chybějící odkazy
- Odkazy se zadávají do php aplikace threat-analysis.sos

From Úřad vlády <vladaceskerepubliky.gov@gmail.com>

Subject **Odlet vládním speciálem**

To david.tvrdy00@gmail.com

Show headers

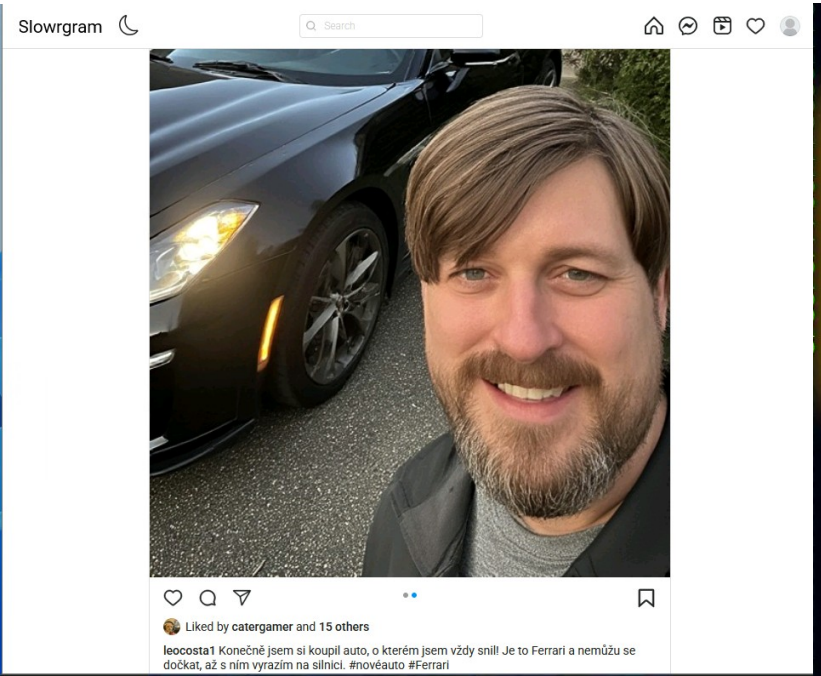
Plain text | Source

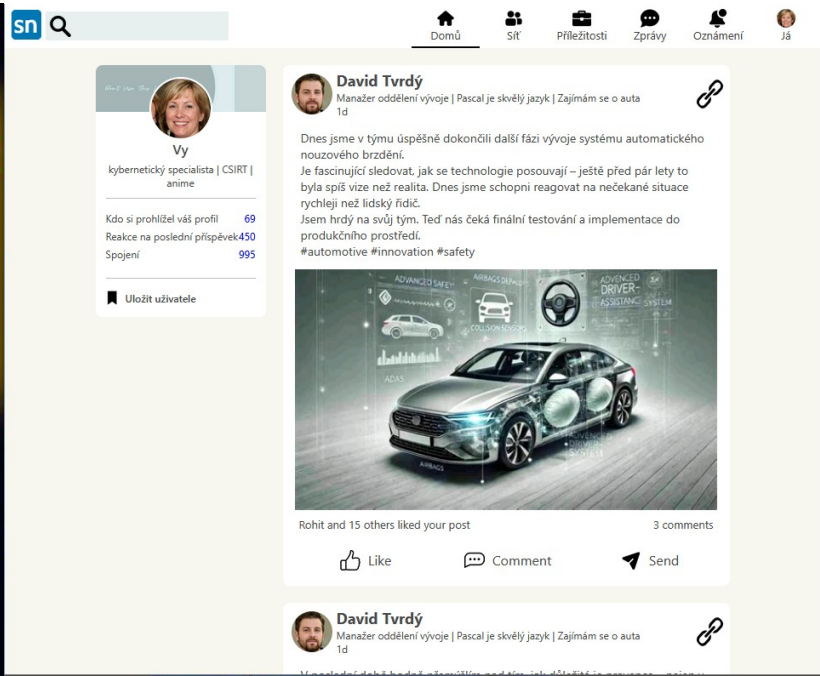
Vážený pane Tvrdý,

Díky registru osob jsme zjistili, že jste odletěl na dovolenou do Dubaje, a jelikož na Blízkém východě došlo ke značnému zhoršení bezpečnostní situace, rozhodla se vláda České republiky
Protože na odlet čeká velké množství lidí, budete muset zaplatit poplatek v hodnotě 4000 Kč.
Pokud tak neučiníte do 12 hodin, budete přesunut až na konec pořadníku.

Informace pro platbu:
Bankovní účet: 670100/2416308917/6210
Variabilní číslo: 4874167187

S pozdravem,
Martina Klacková z Úřadu vlády





Hledání lokace fotky

- Úkol navazuje na předchozí úlohu
- obsahuje fotku z výletu
- Cílem je analyzovat odkud byla vyfocena